

Manual 32 — FFIEC Controlled Implementation

****Language:**** English

****Controlled baseline:**** Active FFIEC Information Technology Examination Handbook materials and applicable member-agency overlays, release-time verified 2026-08-31.

****Boundary:**** FFIEC handbook material is interagency examination guidance. It is not a standalone federal statute and does not replace binding law, agency-specific regulation/order, institution-specific supervisory findings, or qualified legal/regulatory analysis. The FFIEC Cybersecurity Assessment Tool (CAT) was sunset August 31, 2025 and is not used as a current baseline.

Chapter 01 — Purpose, scope, and controlled-source hierarchy

Use current FFIEC IT Handbook booklets as examination-guidance sources and maintain separate references for statutes, regulations, member-agency rules/orders, supervisory statements, and institution-specific commitments. Implementation examples are internal practices, not regulator-approved designs.

Chapter 02 — Institution type, charter, regulator, and applicability analysis

Maintain a regulator/applicability matrix identifying institution type, charter, primary federal regulator, state regulator where applicable, material legal entities, services, technology-service-provider roles, and relevant supervisory overlays. Do not infer examination requirements from a generic label such as bank, credit union, or fintech.

Chapter 03 — FFIEC governance model and board oversight

Translate FFIEC governance concepts into defined board/senior-management oversight, accountability, reporting, escalation, resource allocation, policy approval, and challenge. Retain evidence showing informed oversight of IT and cyber risk rather than agenda presence alone.

Chapter 04 — Enterprise risk-management integration

Integrate IT and cybersecurity risk with enterprise risk management using consistent risk taxonomy, appetite/tolerance, ownership, issue escalation, concentration risk, emerging risk, and change triggers. Preserve differences between supervisory guidance and any binding risk-governance requirement applicable to the institution.

Chapter 05 — Information-security program governance

Maintain an information-security program tied to risk assessment, governance, controls, operations, incident response, testing, and continuous improvement. Map applicable Interagency Information Security Standards and agency-specific requirements separately from FFIEC explanatory guidance.

Chapter 06 — IT architecture and infrastructure governance

Maintain current architecture documentation showing systems, platforms, networks, cloud, data flows, dependencies, resilience design, trust boundaries, and third-party components. Architecture decisions should be risk-assessed, approved, traceable, and available to examiners at an appropriate level of detail.

Chapter 07 — Technology operations and service-management controls

Govern production operations through defined ownership, monitoring, job/process control, capacity, availability, event handling, problem management, service levels, backup, privileged operations, and operational records. Evidence should demonstrate sustained operation rather than policy intent.

Chapter 08 — Development, acquisition, and maintenance governance

Apply the active 2024 FFIEC Development, Acquisition, and Maintenance booklet to planning, acquisition, SDLC, project risk, maintenance, supply-chain risk, security, resilience, and lifecycle decisions. Preserve vendor and internally developed system responsibilities separately.

Chapter 09 — Change and configuration management

Control changes through authorization, risk assessment, testing, segregation of duties, emergency-change governance, configuration baselines, deployment evidence, rollback planning, and post-implementation review. Reconcile unauthorized or failed changes to issue-management processes.

Chapter 10 — Asset inventory and technology lifecycle controls

Maintain authoritative inventories for hardware, software, applications, infrastructure, cloud resources, data platforms, dependencies, owners, criticality, support status, and lifecycle state. Identify unsupported/end-of-life technology and track risk treatment, migration, or approved exception.

Chapter 11 — Identity governance and access administration

Define identity lifecycle, provisioning, role design, approval, least privilege, periodic recertification, transfer/termination, service accounts, external users, and exception controls. Reconcile directories and application entitlements to authoritative identity and HR/vendor records.

Chapter 12 — Authentication and privileged-access controls

Use risk-based authentication and stronger controls for privileged, remote, high-risk, and sensitive access. Document MFA or equivalent control decisions, privileged-account

governance, password/credential protections, monitoring, emergency access, and compensating controls.

Chapter 13 — Data classification, protection, and cryptographic safeguards

Classify information according to sensitivity, legal/regulatory requirements, business impact, customer obligations, and retention. Apply access, encryption, key management, transfer, masking, disposal, backup, and monitoring controls aligned to risk and binding requirements.

Chapter 14 — Network, endpoint, and infrastructure security

Implement layered safeguards for segmentation, firewalls, remote access, endpoint protection, hardened configuration, wireless, email/web controls, administrative interfaces, cloud networking, and infrastructure management. Maintain diagrams, baselines, exceptions, and monitoring evidence.

Chapter 15 — Logging, monitoring, detection, and security analytics

Define required event sources, centralization, retention, alerting, tuning, escalation, analyst responsibilities, investigation records, and coverage validation. Monitoring design should reflect critical assets, threat exposure, legal requirements, and the institution's risk profile.

Chapter 16 — Vulnerability, patch, and exposure management

Operate discovery, vulnerability assessment, prioritization, patching, configuration remediation, external exposure review, exception handling, and verification. Track overdue or unremediated exposures using documented risk acceptance and compensating controls.

Chapter 17 — Secure software and application controls

Apply secure design, requirements, coding, code review, testing, dependency/SBOM or equivalent supply-chain controls where appropriate, secrets management, release approval, maintenance, and vulnerability remediation. Distinguish institution controls from software-provider responsibilities.

Chapter 18 — Cloud, virtualization, and emerging-technology risk

Assess cloud, SaaS, containers, virtualization, AI, automation, APIs, and other emerging technologies through architecture, data, identity, resilience, third-party, concentration, exit, security, and compliance lenses. Do not assume provider assurance eliminates institution accountability.

Chapter 19 — Third-party and technology-service-provider oversight

Maintain risk-based due diligence, contracting, security requirements, performance/assurance review, access oversight, incident notification, resilience,

subcontractor/fourth-party awareness, termination, and exit evidence for relevant providers. Apply applicable statutory or agency-specific TSP requirements separately.

Chapter 20 — Outsourcing governance and concentration-risk controls

Evaluate whether outsourcing creates operational, geographic, systemic, cloud, vendor, platform, skill, data, or recovery concentration. Define tolerance, contingency options, alternate providers, exit feasibility, board/management escalation, and monitoring for material concentrations.

Chapter 21 — Cybersecurity incident response and escalation

Maintain incident governance for detection, triage, severity, containment, eradication, recovery, evidence, communications, legal/regulatory analysis, customer impact, third parties, lessons learned, and remediation. Exercises should test decision-making and dependencies, not only technical playbooks.

Chapter 22 — Regulatory-notification and agency-overlay decision records

Maintain a matrix of notification obligations by regulator, statute/rule, event type, threshold, timing, method, and owner. For each material event, preserve facts, awareness timestamps, legal/regulatory analysis, decision authority, filing evidence, and supplements without using internal severity as a substitute for a legal trigger.

Chapter 23 — Business continuity and disaster recovery

Use the active FFIEC Business Continuity Management guidance to maintain enterprise continuity, technology recovery, communications, dependencies, crisis governance, and testing. Tie business impact analysis, recovery objectives, plans, testing, findings, and remediation to critical services.

Chapter 24 — Operational resilience and scenario testing

Test severe but plausible scenarios across cyber, technology, third party, facilities, workforce, data, and external dependencies. Define objectives, assumptions, decision points, recovery targets, lessons, ownership, and tracked improvements; successful test completion is not itself proof of resilience.

Chapter 25 — Backup, recovery, and restoration assurance

Govern backup scope, frequency, immutability/offline protection where appropriate, access, encryption, retention, monitoring, restoration procedures, recovery dependencies, and testing. Demonstrate recoverability through evidence of successful restores and remediation of failures.

Chapter 26 — Physical and environmental security interfaces

Coordinate IT/cyber controls with facilities, power, cooling, fire protection, physical access, surveillance, data-center/provider controls, environmental monitoring, and alternate-site arrangements. Identify shared responsibilities and evidence for institution-operated and outsourced facilities.

Chapter 27 — Cybersecurity awareness and role-based training

Provide baseline awareness plus role-based training for privileged users, developers, administrators, incident responders, executives, board members, third-party managers, and other risk-relevant roles. Track curriculum, population, completion, exceptions, effectiveness indicators, and changes driven by risk.

Chapter 28 — Independent testing, audit, and assurance

Define independent assurance appropriate to risk, legal requirements, and supervisory expectations. Maintain scope, independence, methodology, population/sample, findings, ratings, management responses, remediation validation, and limits of reliance on third-party reports.

Chapter 29 — Examination readiness and evidence management

Maintain an examination evidence index linking requests to policies, standards, procedures, inventories, risk assessments, governance records, control evidence, tests, issues, and responsible owners. Provide current, reconciled evidence and record explanations for gaps or superseded artifacts.

Chapter 30 — Issue management, remediation, and risk acceptance

Track examination, audit, control, risk, incident, and testing issues with source, severity, root cause, owner, target date, interim controls, validation, and closure evidence. Risk acceptance must have appropriate authority and cannot override a binding requirement or supervisory commitment.

Chapter 31 — Metrics, reporting, supervisory traceability, and continuous improvement

Define metrics with formula, source, population, frequency, owner, threshold, exclusions, and action trigger. Reporting should trace significant risks and issues to decisions and remediation rather than presenting maturity scores or counts as proof of compliance.

Chapter 32 — Release-time source reverification and implementation roadmap

Before each controlled release, revalidate the FFIEC IT Handbook, member-agency guidance/rules, relevant legal requirements, and examination developments. Explicitly

confirm that the retired CAT remains non-current and assess any successor resources, booklet revisions, or agency changes through controlled impact analysis.

Minimum evidence set

Maintain, as applicable: regulator/applicability matrix; board/management oversight; information-security program; risk assessment; architecture and asset inventories; identity/access reviews; authentication/PAM records; data-protection decisions; network/endpoint evidence; logging/monitoring records; vulnerability/patch evidence; development/change evidence; cloud/emerging-technology assessments; TSP/outsourcing/concentration records; incident/notification decisions; BCM/DR and restoration tests; facilities interfaces; training; independent assurance; examination evidence index; issue/risk-acceptance records; metrics/reporting pack; and release-source verification.